

Carrera: Ingeniería en Sistemas de Información

Asignatura: Seguridad en el Desarrollo de Software

Planificación a partir del Ciclo Lectivo 2023

1. Datos administrativos de la asignatura

Nivel en la carrera	4	Duración	Cuatrimestral
Plan	2023		
Bloque curricular:	Asignatura Electiva		
Carga horaria presencial semanal (hs. cátedra):	6 hs	Carga Horaria total (hs. reloj):	72 hs
Carga horaria no presencial semanal (hs. reloj) (si correspondiese)	0 hs	% horas no presenciales (hs. reloj) (si correspondiese)	0 %

2. Presentación, Fundamentación

El ingeniero en Sistemas de Información normalmente se ve involucrado de forma activa en el desarrollo y mantenimiento de software, los cuales almacenan, transfieren y alteran datos sensibles de sus usuarios y, deben ser protegidos bajo mecanismos de seguridad y buenas prácticas de código e implementación.

Esta asignatura se enfoca en plantear soluciones de seguridad al desarrollo de software durante todo el ciclo de vida: requerimientos, análisis, diseño, codificación, testing, despliegue y mantenimiento.

Relación de la asignatura con el perfil de egreso:

Su estudio aporta conceptos, métodos, técnicas y herramientas para enfrentar el desarrollo, mantenimiento e implementación de una arquitectura de software segura que garantice la confidencialidad, integridad y disponibilidad de los datos e información.

Relación de la asignatura con los alcances del título:

La seguridad de la información debe ser considerada en cualquier decisión estratégica de una organización. Esta asignatura aporta los fundamentos para garantizar la seguridad de la información en el software y en procesos de negocios digitalizados por lo que comprenderlos

permitirá planificar, dirigir, ejecutar y controlar el diseño, desarrollo, despliegue y prueba de los sistemas de información conociendo con precisión el nivel de seguridad implementado.

3. Relación de la asignatura con las competencias de egreso de la carrera

En la tabla siguiente se establece la relación de la asignatura con las competencias de egreso: Específicas, Genéricas Tecnológicas y Genéricas Sociales, Políticas y Actitudinales de la carrera. Se incluyen las competencias de egreso a las que tributa, aportes reales y significativos de la asignatura, y en qué nivel (no aporta, bajo, medio, alto).

Competencias	Nivel
Competencias genéricas tecnológicas (CG):	
CG.1. Identificación, formulación y resolución de problemas de ingeniería en sistemas de información/informática.	No aporta
CG.2. Concepción, diseño y desarrollo de proyectos de Ingeniería en Sistemas de Información/Informática	No aporta
CG.3. Gestión, planificación, ejecución y control de proyectos de Ingeniería en Sistemas de Información/Informática.	No aporta
CG.4. Utilización de técnicas y herramientas de aplicación de Ingeniería en Sistemas de Información/Informática.	No aporta
CG.5. Generación de desarrollos tecnológicos y/o innovaciones tecnológicas.	Bajo
Competencias genéricas sociales, políticas y actitudinales (CG)	
CG.6. Fundamentos para el desempeño en equipos de trabajo.	No aporta
CG.7. Fundamentos para una comunicación efectiva.	No aporta
CG.8. Fundamentos para una actuación profesional ética y responsable.	No aporta
CG.9. Fundamentos para evaluar y actuar en relación con el impacto social de su actividad profesional en el contexto global y local.	No aporta
CG.10. Aprender en forma continua y autónoma.	No aporta
CG.11. Fundamentos para el desarrollo de una actitud profesional emprendedora	No aporta
Competencias Específicas de la carrera	
CE1.1. Especificar, proyectar y desarrollar sistemas de información para concebir soluciones tecnológicas que permitan resolver situaciones en las organizaciones mediante el empleo de metodologías de sistemas y tecnologías asociadas a los sistemas de información.	No aporta

CE1.2. Especificar, proyectar y desarrollar sistemas de comunicación de datos, evaluando posibles soluciones tecnológicas disponibles para dar soporte a los sistemas de información en lo referido al procesamiento y comunicación de datos.	No aporta
CE1.3. Especificar, proyectar y desarrollar software para la elaboración de soluciones informáticas con el propósito de resolver problemas estratégicos y operativos, así como de servicios y de negocios, en el marco de una actividad económica que sea social y ambientalmente sustentable.	No aporta
CE2.1. Proyectar y dirigir lo referido a seguridad informática para seleccionar y aplicar técnicas, herramientas, métodos y normas, garantizando la seguridad y privacidad de la información procesada y generada por los sistemas de información.	Alto
CE.3.1. Establecer métricas y normas de calidad de software para medir, evaluar, controlar y monitorear el rendimiento, impulsando mejoras de acuerdo a técnicas y normas vigentes definidas por los organismos de estandarización.	No aporta
CE.4.1. Certificar el funcionamiento, condición de uso o estado de sistemas de información, sistemas de comunicación de datos, software, seguridad informática y calidad de software para asegurar la generación de los resultados deseados en función de restricciones de tiempo y recursos establecidos.	No aporta
CE.5.1. Dirigir y controlar la implementación, operación y mantenimiento de sistemas de información, sistemas de comunicación de datos, software, seguridad informática y calidad de software, a los fines de alcanzar los objetivos fijados por la organización.	Medio
CE.6.1. Asesorar y capacitar a organizaciones, empresas, organismos públicos o privados en la adquisición, instalación y uso, en lo que respecta a sistemas de información, sistemas de comunicación de datos, software, seguridad informática y calidad de software, a los fines de un uso correcto de los sistemas intervinientes.	No aporta
CE.7.1. Realizar pericias, tasaciones y arbitrajes relacionados con su actividad profesional, respetando marcos normativos y jurídicos con el objeto de asesorar a las partes o a los tribunales de Justicia.	No aporta

4. Contenidos Mínimos

No corresponde.

5. Objetivos establecidos en el DC

6. Resultados de aprendizaje

Los siguientes resultados de aprendizaje se promueven en el desarrollo de la asignatura

Identificador de RA	Redacción
RA1	Argumentar la importancia de la seguridad de la información generada y procesada por los sistemas de información con el objetivo de minimizar vulnerabilidades, teniendo en cuenta los pilares de la seguridad informática: confidencialidad, integridad y disponibilidad de los datos.
RA2	Recomendar soluciones de seguridad en el código de software a fin de proteger los datos generados ante ataques cibernéticos habituales.
RA3	Diseñar soluciones de protección en el código e infraestructura de software para prevenir vulnerabilidades cuando el software esté productivo teniendo en cuenta las prácticas de código seguro propuestas por la OWASP.
RA4	Experimentar diferentes tipos de ataques cibernéticos para analizar las consecuencias y determinar mitigaciones durante el desarrollo y mantenimiento de software.

7. Relación de los RA y las competencias

En la tabla siguiente se indica con X la tributación de cada Resultado de Aprendizaje con las competencias de egreso: específicas, genéricas tecnológicas, sociales, políticas y actitudinales de la carrera.

RA	CE1.1	CE1.2	CE1.3	CE2.1	CE3.1	CE4.1	CE5.1	CE6.1	CE7.1	CG1	CG2	CG3	CG4	CG5	CG6	CG7	CG8	CG9	CG10	CG11
RA1	-	-	-	X	-	-	X	-	-	-	-	-	-	-	-	-	-	-	-	-
RA2	-	-	-	X	-	-	-	-	-	-	-	-	-	-	-	-	-	-	-	-
RA3	-	-	-	-	-	-	-	-	-	-	-	-	-	X	-	-	-	-	-	-
RA4	-	-	-	-	-	-	X	-	-	-	-	-	-	-	-	-	-	-	-	-

8. Asignaturas correlativas previas

Para cursar y rendir debe tener cursadas:

- Asignatura/s:
Desarrollo de Software
Base de Datos
Diseño de Sistemas de Información

Para cursar y rendir debe tener aprobada:

- Asignatura/s:
Sistemas Operativos
Sistemas y Procesos de Negocio

9. Asignaturas correlativas posteriores

Indicar las asignaturas correlativas posteriores:

- Asignatura/s:
No corresponde

10. Programa analítico

Este programa analítico contempla los contenidos mínimos, previstos en el DC vigente, y aquellos que se consideran necesarios para desarrollar los resultados de aprendizaje propuestos.

Unidad N°: 1

Título: Seguridad en el software.

Contenidos:

Conceptos básicos de seguridad: disponibilidad, integridad, confidencialidad, autenticación, no repudio.

Seguridad de las aplicaciones en la actualidad.

Desarrollo seguro en el ciclo de vida del desarrollo de software.

Diferencia entre flaw y bug.

Ejemplos de vulnerabilidades en software conocidos y casos reales.

Carga horaria por Unidad: 10 h. cátedra.

Unidad N°: 2

Título: Seguridad en etapas iniciales del ciclo de desarrollo de software.

Contenidos:

Análisis de riesgos.
Identificación y descripción de casos de abuso y amenazas.
Seguridad en Agile.

Carga horaria por Unidad: 20 h. cátedra.

Unidad N°: 3

Título: Código orientado a la seguridad.

Contenidos:

OWASP: top 10 (presentación de las vulnerabilidades más comunes - mecanismos para mitigarlas).
Identificación de roles de usuarios y permisos.
Control de acceso: identificación, autenticación y autorización.
Implementación de mecanismos de autenticación.
Implementación de mantenimiento de sesión en aplicaciones web.
Implementación de autenticación por más de un factor.
Técnicas para guardar información sensible. Criptografía aplicada: métodos de cifrado de datos.
Implementación segura del proceso para recuperación de clave en una aplicación web.
Consultas a bases de datos de manera segura: uso de procedimientos almacenados, sentencias preparadas y usuarios en BD.
Sanitizar datos para evitar ataques de XSS y CSRF.
Gestión de errores y logs.
Seguridad en APIs REST. Validación de entradas.
OWASP API Security top 10.
Ambientes de desarrollo seguro.
Buenas prácticas de desarrollo mobile. Vulnerabilidades más comunes en aplicaciones móviles.

Carga horaria por Unidad: 26 h. cátedra.

Unidad N°: 4

Título: Despliegue en ambientes seguros.

Contenidos:

Aspectos a tener en cuenta para una configuración segura de una infraestructura.
Aspectos a tener en cuenta para una configuración segura en bases de datos.
Protocolos SSL y HTTPS. Certificados SSL.
Contenedores.
El rol del DevSecOps.

Carga horaria por Unidad: 20 h. cátedra.

Unidad N°: 5

Título: Pentesting de aplicaciones.

Contenidos:

Conceptos de RedTeam y BlueTeam.
 Concepto de pentesting.
 Tipos de pentesting: whitebox y blackbox.
 Técnicas, metodología y etapas de pentesting según su tipo.
 Herramientas para hacer pentesting web / mobile.
 Herramientas de análisis de código (Dinámico - Estático).
 Reporte final técnico y ejecutivo.
 Prácticas con Capture The Flag.

Carga horaria por Unidad: 20 h. reloj.

Carga horaria por tipo de formación práctica de toda la asignatura

Tipo de formación práctica	Horas reloj
Formación experimental	16
Análisis y resolución de problemas de ingeniería y estudios de casos	12
Formulación, análisis y desarrollo de proyectos.	12

Bibliografía Obligatoria:

- OWASP. *Authentication Cheat Sheet*.
https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- OWASP. *Password Storage Cheat Sheet*.
https://www.owasp.org/index.php/Password_Storage_Cheat_Sheet
- OWASP. *Password Storage Cheat Sheet*.
https://www.owasp.org/index.php/Forgot_Password_Cheat_Sheet
- OWASP. *OWASP API Security Project*.
<https://owasp.org/www-project-api-security/>
- Larry Conklin y Gary Robinson (2017). *CODE REVIEW GUIDE 2.0* [Archivo PDF]
https://owasp.org/www-pdf-archive/OWASP_Code_Review_Guide_v2.pdf
- OWASP. *Source Code Analysis Tools*.
https://owasp.org/www-community/Source_Code_Analysis_Tools
- OWASP. *OWASP Web Security Testing Guide*.
<https://owasp.org/www-project-web-security-testing-guide/>
- Aumasson, Jean Phillippe (2017). *Serious cryptography: a practical introduction to modern encryption*. No Starch Press.
- Loren Kohnfelder (2021). *Designing Secure Software - A Guide for Developers*. No Starch Press.

Bibliografía optativa y otros materiales a utilizar en la asignatura:

- Pinto Marcus y Stuttard D. (2011). *The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws*. John Wiley & Sons Inc.
- Anderson, Ross (2008). *Security Engineering*. Wiley.
- Tanner, N. (2019). *Cybersecurity blue team toolkit*. Wiley.
- OWASP. *OWASP Web Security Testing Guide*.
<https://owasp.org/www-project-web-security-testing-guide/>

- Najera Gutierrez Gilberto y Ansari June (2018). *Web penetration testing with Kali Linux* (3ra ed.). Packt Publishing.
- Shostack, Adam (2014). *Threat modeling: Designing for Security*. Wiley.
- SANS Information Security White Papers (<https://www.sans.org/reading-room/whitepapers/testing>).
- APISecurity (<https://apisecurity.io/>).
- Cloud Security - Securing Thin Air (<https://www.sans.org/cloud-security/>).
- MongoDB. *How to Avoid a Malicious Attack That Ransoms Your Data*. <https://www.mongodb.com/blog/post/how-to-avoid-a-malicious-attack-that-ransoms-your-data>
- Friedl, J. (2006). *Mastering regular expressions*. O'Reilly Media.

11. Metodología de enseñanza

En el aula se trabajará planteando casos reales y demostraciones de problemas de seguridad en el software. Durante la misma clase se discutirán soluciones y, al finalizar la misma, se plantearán las soluciones ya estandarizadas con sus posibles variantes. En determinadas clases, se realizarán ejercicios prácticos donde el estudiante pueda aplicar todo el conocimiento abordado en esa clase y en las anteriores.

De manera asincrónica, los estudiantes podrán acceder a un aula virtual con cuestionarios, artículos de interés, píldoras informativas en formato de video, guías de ejercicios y tutoriales.

Se priorizará el tiempo en clases para el abordaje de actividades prácticas, discusiones y demostraciones mientras que se utilizará el aula virtual para el abordaje de conceptos teóricos.

12. Recomendaciones para el estudio

La asignatura aborda una variedad de temas prácticos que requieren que el estudiante trabaje e intente resolver los ejercicios cada semana. El estudiante necesita comprender aspectos básicos de desarrollo de software y tener iniciativa autodidacta.

Además, se recomienda que cada estudiante arme un glosario de los términos utilizados ya que es común que las vulnerabilidades, tipos de ataques y mecanismos de defensas tengan nombres en formato de siglas.

13. Metodología de evaluación

El modelo de enseñanza basado en competencias implica la aplicación de metodologías e instrumentos de evaluación que permiten conocer, a docentes y estudiantes, el nivel de desarrollo de las competencias que aborda la asignatura.

Se hace una *evaluación diagnóstica* con un trabajo grupal en la primera clase, donde se buscan distinguir los conceptos previos que el grupo posee. Posterior a esta instancia se realiza una situación de puesta en común entre todos los estudiantes como actividad enriquecedora de conceptos previos.

Parciales:

- 1 parcial teórico/práctico
- 1 recuperatorio (se conserva la mejor calificación).

Además, se exige un Trabajo Final Integrador con los contenidos abordados en la materia, a desarrollar de manera grupal y con exposición oral.

También al finalizar algunas clases se realizan cuestionarios con respuestas automáticas inmediatas para que el estudiante pueda autoevaluarse.

A continuación, se detallan todos los Resultados de Aprendizajes con sus contenidos a desarrollar para alcanzarlos, la mediación pedagógica, metodologías y estrategias de evaluación, tiempo en horas reloj.

Resultados de Aprendizaje	Contenidos según programa	Mediación Pedagógica	Metodología y Estrategias de Evaluación	Tiempos en hora reloj
RA 1	- Unidad nro. 1: Seguridad en el software. - Unidad nro. 2: Seguridad en etapas iniciales del ciclo de vida del desarrollo de software.	Estrategias: - Lección magistral participativa. - Estudio de casos. Actividades: - Evaluación de riesgos en los casos de estudio. - Estructuración de casos de abuso en situaciones hipotéticas que suceden en el desarrollo ágil. - Identificación de amenazas presentes en un sistema de información considerando la confidencialidad, integridad y	Instrumentos: - Cuestionarios. - Ejercicios prácticos. - Parcial. Criterios: - Justifica la valoración de cada riesgo. - Estructura casos de abuso aplicados en el desarrollo ágil. - Plantea amenazas a tener en cuenta en un caso de estudio.	Horas presenciales teóricas/prácticas: 12 Horas extra aúlicas: 4

		disponibilidad de los datos.		
RA 2	Unidad nro. 3: Código orientado a la seguridad.	Estrategias: - Lección magistral participativa. - Resolución de ejercicios. - Demostraciones de escenarios con vulnerabilidades y soluciones. Actividades: - Resolución de ejercicios definidos en una guía de ejercicios. - Análisis del impacto de ataques cibernéticos en diferentes escenarios y simulaciones. - Selección de soluciones de códigos seguro para mitigar vulnerabilidades de acuerdo a OWASP. - Detección de tareas que se deben realizar para minimizar el riesgo de código inseguro. - Resolución del Trabajo Práctico grupal.	Instrumentos: - Trabajo Práctico grupal. - Parcial. Criterios: - Identifica vulnerabilidades en el código de software. - Reconoce ataques habituales en diferentes escenarios. - Justifica las soluciones que aplica para mitigar vulnerabilidades. - Participa en el trabajo práctico grupal de manera activa.	Horas presenciales teóricas/prácticas: 22 Horas extra aúlicas: 6

RA 3	- Unidad nro. 3: Código orientado a la seguridad. - Unidad nro. 4: Despliegue en ambientes seguros.	Estrategias: - Lección magistral participativa. - Resolución de ejercicios. - Casos de estudio. Actividades: - Desarrollo de código con buenas prácticas de seguridad de acuerdo a OWASP. - Diseño de configuraciones seguras en la infraestructura según OWASP. - Implementación de cambios de seguridad en entornos productivos simulados. - Resolución del Trabajo Práctico grupal.	Instrumentos: - Trabajo Práctico grupal. - Parcial. Criterios: - Aplica las reglas de código seguro de acuerdo a OWASP. - Elabora soluciones seguras de código e infraestructura de acuerdo a OWASP. - Propone cambios de seguridad en entornos productivos simulados y escenarios controlados. - Demuestra que las soluciones que propone son seguras.	Horas presenciales teóricas/prácticas: 22 Horas extra aúlicas: 8
RA 4	Unidad nro. 5: Pentesting de aplicaciones.	Estrategias: - Lección magistral participativa. - Casos de estudio. - Resolución de ejercicios. Actividades:	Instrumentos: - Trabajo Práctico grupal. - Parcial. Criterios:	Horas presenciales teóricas/prácticas: 16 Horas extra aúlicas: 8

		• Experimentación con ataques cibernéticos. • Análisis de las consecuencias de los ataques cibernéticos. • Resolución de ejercicios para encontrar vulnerabilidades en escenarios controlados. • Resolución del Trabajo Práctico grupal.	• Descubre la importancia de aplicar los estándares de código seguro durante el desarrollo y mantenimiento de software. • Comprende las consecuencias de los ataques cibernéticos más frecuentes. • Maximiza el esfuerzo por encontrar soluciones que mitiguen y/o solucionen vulnerabilidades.	
--	--	---	---	--

14. Condiciones de aprobación

Aprobación Directa – Las condiciones son:

- Parcial aprobado (nota igual o superior a 4), pudiendo acceder al recuperatorio (se conserva la mejor nota).
- Trabajo Práctico grupal aprobado con todos los requerimientos necesarios y nota igual o superior a 7.
- Promedio final igual o superior a 6.

La escala de notas para el parcial es:

NOTA	PORCENTAJE	CALIFICACIÓN
1		Insuficiente
2		Insuficiente
3		Insuficiente
4	60% a 66%	Aprobado
5	67% a 71%	Aprobado
6	72% a 77%	Bueno
7	78% a 83%	Bueno
8	84% a 89%	Muy Bueno
9	90% a 94%	Distinto
10	95% a 100%	Sobresaliente

15. Modalidad de examen

La Evaluación Final de la asignatura será a través de un parcial y un trabajo práctico grupal, el que podrá consistir en:

- El desarrollo de software con algunas funcionalidades vulnerables y con sus soluciones.
- La presentación de un trabajo monográfico de investigación básica o exploratoria de alguna herramienta o técnica de seguridad informática ofensiva.
- La configuración de una infraestructura de software utilizando prácticas seguras.

En cualquiera de los casos, este trabajo práctico grupal será realizado durante el periodo de dictado de la asignatura.

16. Recursos necesarios

Espacio físico: Laboratorio informático.

Recursos tecnológicos de apoyo: proyector multimedia, software, aula virtual.

Anexo I: Plantel docente de la asignatura			
Titular	Especifique Nombre y Apellido completo.	Dedicación:	Especifique la cantidad de dedicaciones.
Asociado	Especifique Nombre y Apellido completo.	Dedicación:	Especifique la cantidad de dedicaciones.
Adjunto:	Especifique Nombre y Apellido completo.	Dedicación:	Especifique la cantidad de dedicaciones.
Jefe de Trabajos Prácticos	Especifique Nombre y Apellido completo.	Dedicación:	Especifique la cantidad de dedicaciones.
Auxiliar de 1ra.	Especifique Nombre y Apellido completo.	Dedicación:	Especifique la cantidad de dedicaciones.
Auxiliar de 2da.	Especifique Nombre y Apellido completo.	Dedicación:	Especifique la cantidad de dedicaciones.

FIRMA (Jefe o encargado de cátedra).

Anexo II: Cronograma de clases/trabajos prácticos/evaluaciones (por comisión)

COMISIÓN: Indique la comisión.			
Nro. de Semana	Fecha	Tema	Tipo de Actividad
1	Indique la fecha	Describa el tema trabajado	Seleccione el tipo de actividad.

FIRMA (de cada docente que conforman la comisión).